An official website of the United States government Here's how you know

America's Cyber Defense Agency
NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

Archived Content

In an effort to keep CISA.gov current, the archive contains outdated information that may not reflect current policy or programs.

ICS ADVISORY

Baxter SIGMA Spectrum Infusion System Vulnerabilities

Last Revised: September 29, 2015 **Alert Code:** ICSA-15-181-01

OVERVIEW

This advisory was originally posted to the US-CERT secure Portal library on June 30, 2015, and is being released to the NCCIC/ICS-CERT web site.

Researcher Jared Bird with Allina IS Security identified four vulnerabilities in Baxter's SIGMA Spectrum Infusion System. Baxter has released a new version of the SIGMA Spectrum Infusion System, Version 8 that incorporates hardware and software changes, which do not contain three of the four identified vulnerabilities.

Three of the four vulnerabilities are remotely exploitable.

AFFECTED PRODUCTS

The following SIGMA Spectrum Infusion System versions are affected:

- SIGMA Spectrum Infusion System, Version 6.05 (model 35700BAX) with wireless battery module (WBM), Version 16. The WBM is a stand-alone component that provides network connectivity to the pump.

IMPACT

Successful exploitation of these vulnerabilities may allow a remote attacker to make unauthorized configuration changes to the WBM and gain information about the host network such as wireless account credentials. According to Baxter, it is not possible to change infusion parameters using the identified vulnerabilities. In addition, the SIGMA Spectrum Infusion Pump does not contain any personally identifiable information or patient health information.

Impact to individual organizations depends on many factors that are unique to each organization. ICS-CERT recommends that organizations evaluate the impact of these vulnerabilities based on their operational environment and specific clinical usage.

BACKGROUND

Baxter is a US-based company that maintains offices worldwide, including the US, UK, Italy, India, Germany, France, China, and Australia.

The affected product, the SIGMA Spectrum Infusion System, is an intravenous pump that delivers medication to patients. According to Baxter, SIGMA Spectrum Infusion Systems are deployed across the Healthcare and Public Health sector. Baxter estimates that these products are used in the US and Canada.

VULNERABILITY CHARACTERIZATION

VULNERABILITY OVERVIEW

USE OF HARD-CODED PASSWORDCWE-259: Use of Hard-coded Password, http://cwe.mitre.org/data/definitions/259.html, web site last accessed June 30, 2015.

Baxter's SIGMA Spectrum infusion pumps contain a hard-coded password, which provides access to basic biomedical information, limited device settings, and network configuration of the WBM, if connected. The hard-coded password may allow an attacker with physical access to the device to access management functions to make unauthorized configuration changes to biomedical settings such as turn on and off wireless connections and the phase-complete audible alarm that indicates the end of an infusion phase.

CVE-2014-5431NVD, http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2014-5431, NIST uses this advisory to create the CVE web site report. This web site will be active sometime after publication of this advisory. has been assigned to this vulnerability. A CVSS v2 base score of 4.6 has been assigned; the CVSS vector string is (AV:L/AC:L/Au:N/C:P/I:P/A:P).CVSS Calculator, http://nvd.nist.gov/cvss.cfm?version=2&vector=AV:L/AC:L/Au:N/C:P/I:P/A:P, web site last accessed June 30, 2015.

AUTHENTICATION BYPASS ISSUESCWE-592: Authentication Bypass Issues, http://cwe.mitre.org/data/definitions/592.html, web site last accessed June 30, 2015.

The WBM is remotely accessible via Port 22/SSH without authentication. A remote attacker may be able to make unauthorized configuration changes to the WBM, as well as issue commands to access account credentials and shared keys. Baxter asserts that this vulnerability only allows access to features and functionality on the WBM and that the SIGMA Spectrum infusion pump cannot be controlled from the WBM.

CVE-2014-5432NVD, http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2014-5432, NIST uses this advisory to create the CVE web site report. This web site will be active sometime after publication of this advisory. has been assigned to this vulnerability. A CVSS v2 base score of 7.5 has been assigned; the CVSS vector string is (AV:N/AC:L/Au:N/C:P/I:P/A:P).CVSS Calculator, http://nvd.nist.gov/cvss.cfm?version=2&vector=AV:N/AC:L/Au:N/C:P/I:P/A:P, web site last accessed June 30, 2015.

CLEARTEXT STORAGE OF SENSITIVE INFORMATIONCWE-312: Cleartext Storage of Sensitive Information, http://cwe.mitre.org/data/definitions/312.html, web site last accessed June 30, 2015.

An unauthenticated remote attacker may be able to execute commands to view wireless account credentials that are stored in cleartext on the WBM, which may allow an attacker to gain access the host network.

CVE-2014-5433NVD, http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2014-5433, NIST uses this advisory to create the CVE web site report. This web site will be active sometime after publication of this advisory. has been assigned to this vulnerability. A CVSS v2 base score of 9.0 has been assigned; the CVSS vector string is (AV:N/AC:L/Au:N/C:C/I:P/A:P).CVSS Calculator, http://nvd.nist.gov/cvss.cfm?version=2&vector=AV:N/AC:L/Au:N/C:C/I:P/A:P, web site last accessed June 30, 2015.

USE OF HARD-CODED PASSWORDCWE-259: Use of Hard-coded Password, http://cwe.mitre.org/data/definitions/259.html, web site last accessed June 30, 2015.

The WBM has a default account with hard-coded credentials used with the FTP protocol. Baxter asserts no files can be transferred to or from the WBM using this account.

CVE-2014-5434NVD, http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2014-5434, NIST uses this advisory to create the CVE web site report. This web site will be active sometime after publication of this advisory. has been assigned to this vulnerability. Baxter has

assigned a CVSS v2 base score of 5.0; the CVSS vector string is (AV:N/AC:L/Au:N/C:P/I:N/A:N).CVSS Calculator, http://nvd.nist.gov/cvss.cfm?version=2&vector=AV:N/AC:L/Au:N/C:P/I:N/A:N, web site last accessed June 30, 2015.

VULNERABILITY DETAILS

EXPLOITABILITY

Three of the four vulnerabilities could be exploited remotely. Exploitation of the hard-coded password vulnerability requires local access.

EXISTENCE OF EXPLOIT

No known public exploits specifically target these vulnerabilities.

DIFFICULTY

An attacker with a low skill level would be able to exploit these vulnerabilities.

MITIGATION

Baxter offers the following recommendations to help mitigate risks associated with these vulnerabilities in the SIGMA Spectrum Infusion System running Version 6.05 with WBM Version 16.

- Ensure that the WI-FI network supporting WBMs is secured using a secure WI-FI protocol.
- Separate the network supporting the WBMs with a standalone VLAN or use similarly segmented network topography to isolate WBMs. This would require an attacker to compromise the standalone WI-FI network or otherwise gain access to the supporting VLAN before SSH access to the WBM is possible.
- Configure Wireless Access Points and Firewalls, which provide access to the VLAN, to block Port 21/FTP and Port 22/SSH.

- Ensure that network authentication credentials used by the WBM to connect to the network are properly restricted to only allow access to the wireless network.
- As a last resort, customers may disable wireless operation of the pump. The Sigma Spectrum Infusion System was designed to operate without network access. This action would impact an organization's ability to rapidly deploy drug library (formulary) updates to their pumps.

Baxter states that it has implemented a process to continually evaluate cybersecurity risks and has defined a roadmap to mitigate vulnerabilities. Baxter has released a new version of the SIGMA Spectrum Infusion System, Version 8, which incorporates hardware and software changes that do not contain three of the four identified vulnerabilities. In Version 8, Baxter has addressed the authentication bypass issue by removing the SSH service from the WBM. The new version addresses the clear text storage of sensitive information through modifications to the commands used to expose network and WI-FI credentials on the WBM; security key information is now masked or otherwise removed from command outputs. Furthermore, the path to gain access to these commands is closed, as the SSH service has been removed. In Version 8, Baxter has addressed the FTP hard-coded password vulnerability by removing the FTP service from the WBM. Baxter has engaged an independent security expert to confirm that Version 8 does not contain the three remotely exploitable vulnerabilities.

Baxter has performed a cybersecurity risk analysis and has evaluated the potential impact of the hard-coded password to access the device as being low. Baxter plans to address this in a future release. Baxter recommends that facilities employ physical security controls to ensure the safety of the pump and WBM.

For additional information about the vulnerabilities, compensating measures, or the new version of the SIGMA Spectrum Infusion System, contact Baxter Technical Support at: 1-800-843-7867 or via email at: gts@baxter.com.

ICS-CERT encourages asset owners to take additional defensive measures to protect against this and other cybersecurity risks.

- Minimize network exposure for all medical devices and/or systems and ensure that they are not accessible from the Internet.
- Locate all medical devices and/or systems behind firewalls and isolate them from the business network.
- When remote access is required, use secure methods, such as Virtual Private Networks (VPNs), recognizing that VPNs may have vulnerabilities and should be updated to the most current version available. Also recognize that VPN is only as secure as the connected devices.

ICS-CERT also provides a section for security recommended practices on the ICS-CERT web page at: http://ics-cert.us-cert.gov/content/recommended-practices </ics/content/recommended-practices>. ICS-CERT reminds organizations to perform proper impact analysis and risk assessment prior to deploying defensive measures.

Additional mitigation guidance and recommended practices are publicly available in the ICS-CERT Technical Information Paper, ICS-TIP-12-146-01B--Targeted Cyber Intrusion Detection and Mitigation Strategies </ics/tips/ics-tip-12-146-01b>, that is available for download from the ICS-CERT web site (http://ics-cert.us-cert.gov/ </ics/>).

Organizations observing any suspected malicious activity should follow their established internal procedures and report their findings to ICS-CERT for tracking and correlation against other incidents.

This product is provided subject to this Notification </notification> and this Privacy & Use </privacy-policy> policy.

Vendor

- Baxter

Please share your thoughts

We recently updated our anonymous product survey; we welcome your feedback.

Return to top

Topics </topics> **Spotlight** </spotlight> **Resources & Tools** </resources-tools>

News & Events </news-events> **Careers** </careers> **About** </about>

CISA Central

1-844-Say-CISA contact@cisa.dhs.gov

CISA.gov
An official website of the U.S. Department of Homeland Security

About CISA </about>

Budget and Performance <https://www.dhs.gov/performance-financial-reports>

DHS.gov <https://www.dhs.gov>

FOIA Requests <https://www.dhs.gov/foia>

No FEAR Act </no-fear-act>

Office of Inspector General <https://www.oig.dhs.gov/>